

PKI (Public Key Infrastructure)

1. Overview

Public Key Infrastructure (PKI) is the overall system of **policies, roles, procedures, hardware, and software** required to create, manage, distribute, use, store, and revoke **digital certificates** and manage public-key encryption at scale.

PKI solves the fundamental problem asymmetric cryptography leaves open:

| A public key alone proves nothing about *who* actually owns it.

PKI provides the trusted binding between a **public key** and a **verified real-world identity**.

PKI at a Glance

Property	Detail
Purpose	Bind public keys to verified identities via trusted third parties
Core artifact	Digital certificate
Core trust mechanism	Digital signatures issued by a Certificate Authority
Key participants	Certificate Authority (CA), Registration Authority (RA), end entities, relying parties

2. The Problem PKI Solves — The Key Distribution Problem

Asymmetric cryptography, such as **RSA and ECC**, relies on freely distributing a public key.

However, if an attacker can trick a victim into using the **attacker's public key** while believing it belongs to a legitimate party, every security guarantee asymmetric cryptography offers can collapse.

The attacker could:

- Decrypt messages intended for the real recipient.
- Forge signatures the victim believes came from someone else.

This is the **key distribution problem**.

PKI's entire purpose is solving this problem through a chain of trusted, verifiable identity attestations.

3. Core PKI Participants and Roles

Role	Function
Certificate Authority (CA)	The trusted entity that verifies identity and digitally signs certificates, vouching that a given public key genuinely belongs to the named subject.
Registration Authority (RA)	Handles identity verification on the CA's behalf before a certificate request is approved and forwarded to the CA for signing.
End entity / subscriber	The person, organization, or system whose identity and public key are bound together in the certificate.
Relying party	Anyone who receives and trusts a certificate, verifying its validity before trusting the claims it makes.
Verification Authority	Validates signatures and certificate status on behalf of a relying party, checking the certificate against the issuing CA and revocation status.

4. How Trust Is Established — The Chain of Trust

PKI trust is hierarchical, rooted in a small set of highly protected **root CAs**.

PKI Chain of Trust



How the Chain Is Verified

A relying party trusts a leaf certificate by **walking the chain upward**:

1. Verify the leaf certificate's signature against the **Intermediate CA's public key**.
2. Verify the Intermediate CA's certificate signature against the **Root CA's public key**.
3. Confirm that the chain terminates at a **Root CA already trusted by the relying party's system**.

Root CAs are typically pre-installed in an **operating system or browser trust store**.

Why Root CAs Are Highly Protected

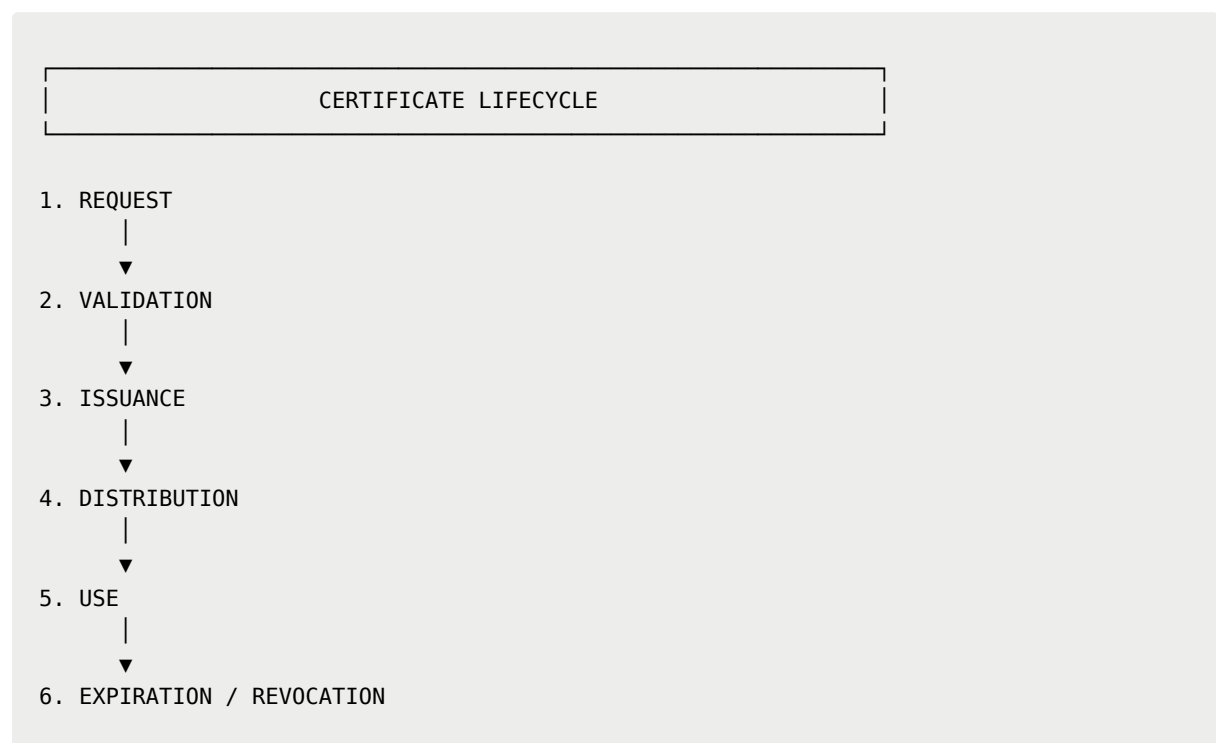
Root CAs are kept especially well protected, often **offline except during rare signing ceremonies**.

This is because compromising a root CA could allow an attacker to **forge trust for essentially any identity beneath it**.

Key point: The root CA is the trust anchor at the top of the PKI hierarchy.

5. The Certificate Lifecycle

A certificate passes through several stages from creation to eventual expiration or revocation.



Lifecycle Steps

Step	Process	Description
1	REQUEST	The subscriber generates a key pair and submits a Certificate Signing Request (CSR) containing their public key and identifying information.
2	VALIDATION	The Registration Authority verifies the requester's identity. The scope of verification varies according to the validation level.
3	ISSUANCE	The Certificate Authority signs the certificate, binding the verified identity to the public key.
4	DISTRIBUTION	The signed certificate is delivered to the subscriber and/or published where relying parties can retrieve it.
5	USE	The certificate is presented to relying parties, for example during a TLS handshake , for verification.
6	EXPIRATION / REVOCATION	Certificates carry a validity period and expire. They may also be revoked earlier if a private key is compromised or the certificate was mis-issued.

6. Certificate Revocation

A certificate's stated validity period may extend beyond the point where it should still be trusted.

For example, if a **private key is compromised**, the corresponding certificate may need to be invalidated before its normal expiration date.

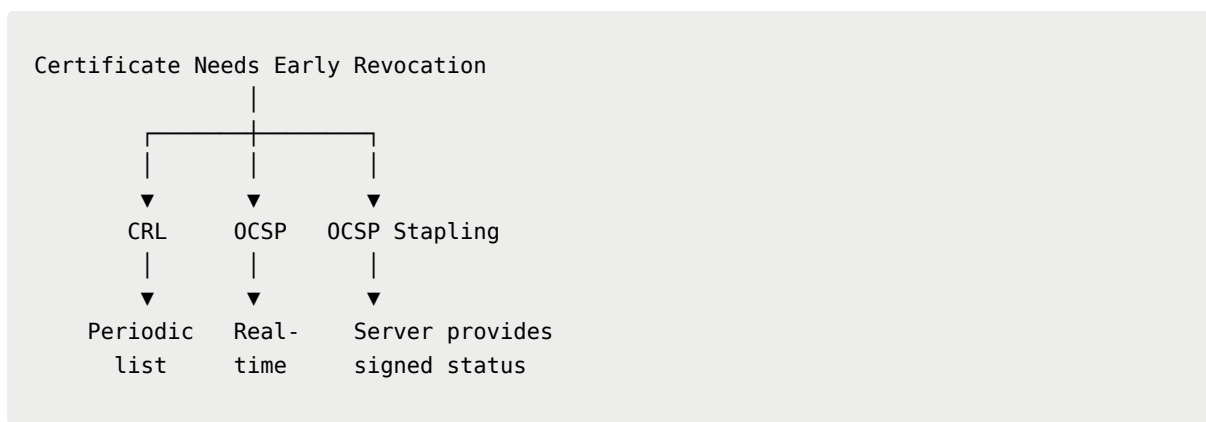
PKI therefore includes mechanisms for communicating early revocation.

Revocation Mechanisms

Mechanism	How It Works	Limitation
CRL (Certificate Revocation List)	The CA periodically publishes a signed list of revoked certificate serial numbers.	Can grow large; relying parties may not always check it or may only refresh it periodically.
OCSP (Online Certificate Status Protocol)	A relying party queries the CA in real time for a specific certificate's current status.	Introduces a real-time dependency on the CA's availability and raises privacy considerations because the

		CA learns which certificates are being checked.
OCSP Stapling	The certificate holder, such as a web server, periodically obtains a signed OCSP response from the CA and "staples" it directly to the TLS handshake.	Removes the relying party's need to contact the CA directly, improving both performance and privacy.

Revocation Comparison



7. Key Management Considerations

Private Key Protection

Private key protection is the single most critical operational concern in any PKI deployment.

A compromised private key undermines every guarantee its corresponding certificate provides because anyone possessing it can impersonate the certificate's subject.

Hardware Security Modules (HSMs)

Hardware Security Modules (HSMs) are frequently used to generate and store **CA private keys** and sometimes high-value end-entity keys.

They keep key material physically isolated from general-purpose systems.

Key Rotation

Key rotation involves periodically issuing new key pairs and certificates.

This limits the exposure window if a key is eventually compromised without the compromise being immediately detected.

8. Typical Use Cases

PKI is commonly used for:

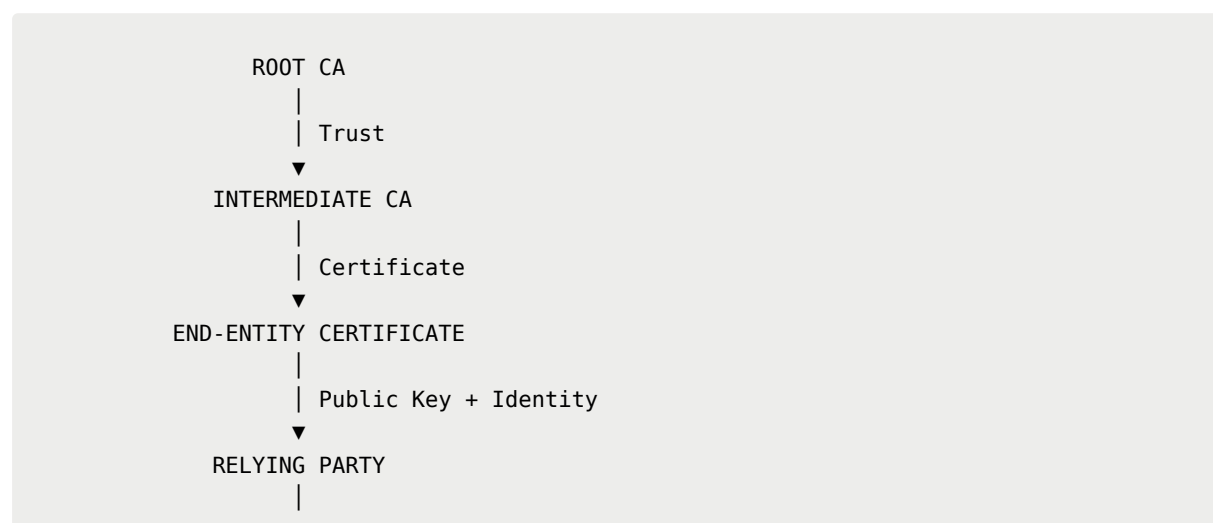
- **TLS/HTTPS website certificates** — the most visible and widespread PKI deployment.
 - **Code signing certificates** for software publishers.
 - **S/MIME email encryption and signing certificates.**
 - **Enterprise/internal PKI** for authenticating devices, VPN clients, and internal services, often using a private, organization-run CA rather than a public one.
 - **Smart card and identity document authentication systems.**
-

9. Summary

PKI is the **organizational and technical framework that makes public-key cryptography trustworthy at scale.**

It establishes a **chain of verifiable trust**, rooted in a small set of highly protected **root CAs**, that binds public keys to real-world identities through digitally signed certificates.

PKI Trust Model



PKI Security Depends On

1. **Rigorous identity validation** during certificate issuance.
2. **Careful private-key protection**, especially at the CA level.
3. **Reliable certificate revocation mechanisms** when trust needs to be withdrawn early.

Bottom line: PKI does not replace asymmetric cryptography. It provides the **trust framework that allows asymmetric cryptography to be used reliably at scale by binding public keys to verified identities.**